off & on again

White Documentation - Team 3

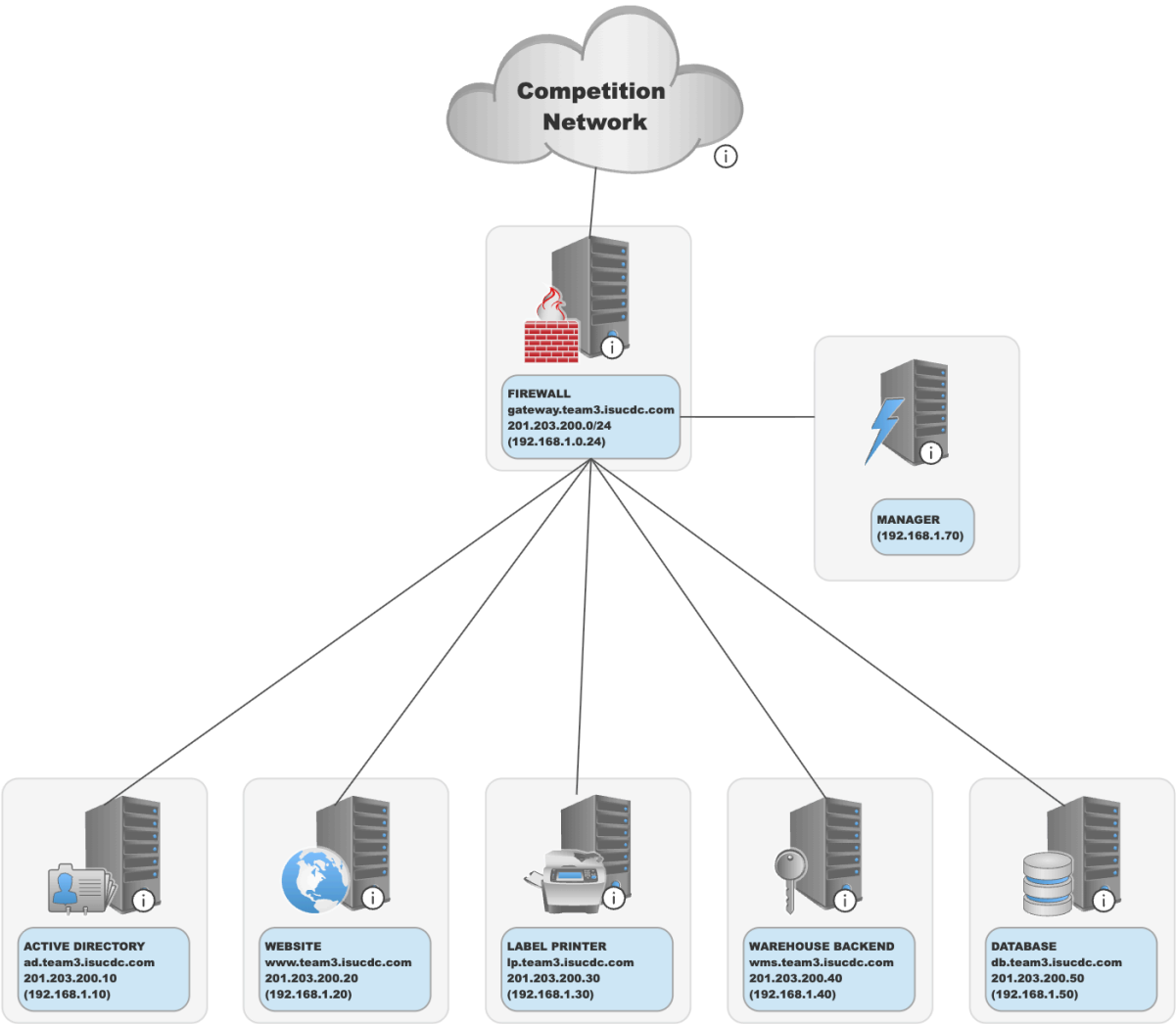
Table of Contents

Network Structure..... 3
- Standard Services..... 4
- Additional Services..... 4

Security Measures..... 6
- Active Directory..... 6
- Website..... 6
- Label Printer..... 6
- Warehouse Management System..... 7
- Database..... 7
- Broad Hardening Techniques..... 7
- Incident Response..... 7

Network Structure

To better secure the company, a pfSense firewall has been applied across the Fahrenheit network. In addition, a Manager system, running the Wazuh security platform, is running internally and segmented from the competition network. The full structure is detailed in the below diagram.



The pfSense firewall is configured with 1:1 NAT mappings on the WAN interface, translating each service's public IP directly to its corresponding internal IP. This is shown in the figure above. Each mapping is one-to-one rather than using port-forwarding or a shared outbound NAT address, meaning each service maintains a dedicated public identity while remaining isolated behind the firewall on the 192.168.1.0/24 internal subnet. The Manager system (192.168.1.70) intentionally has no NAT mapping and is therefore completely unreachable from the Competition Network. The Manager is allowed internal access to each machine to perform security audits and additional maintenance.

Standard Services

The following standard services are available on the network.

Service	Domain Name	Public IP	Port: Service
Active Directory	ad.team3.isucdc.com	201.203.200.10	389: LDAP 3389: RDP
Website	www.team3.isucdc.com	201.203.200.20	22: SSH 80: HTTP
Label Printer	lp.team3.isucdc.com	201.203.200.30	445: SMB 3389: RDP
Warehouse Management System	wms.team3.isucdc.com	201.203.200.40	22: SSH 8080: HTTP
Database	db.team3.isucdc.com	201.203.200.50	22: SSH 3306: MySQL

Additional Services

In addition to the services initially delivered by the company, a pfSense firewall and Wazuh security platform, which are not externally accessible, have been installed. Using firewall rules, the traffic between each server, and between the servers and the Competition Network, is filtered and monitored. The firewall employs a global block of all traffic, logging all such requests, with select superseding rules for each required port. Such rules follow the Principle of Least Privilege, such that each superseding rule is

scoped to only the ports required for that service's documented function. For example, the Active Directory server is permitted only ports 389 (LDAP) and 3389 (RDP); no other inbound traffic is allowed to that host. Monitoring, detection, and response to threat actors is centralized using the Wazuh manager, running on ParrotOS. Each Standard Service runs a Wazuh agent which returns logs, events, and other data to the manager. The manager can then connect to other machines internally to perform security-related actions. Additionally, custom Wazuh logging and rules were created for the frontend and backend services.

Security Measures

Active Directory

Windows Server 2016 Standard Evaluation

The AD server has been updated with cumulative security updates, an updated installation of Windows Defender, and a set of group policy updates to mitigate risk on its available services, LDAP and RDP. LDAP signing & channel binding, NLA, TLS, and High Encryption, are enforced, and extraneous services have been disabled. To better enforce user security, users were wiped and recreated under strict groups. All other machines were domain-joined to the Active Directory such that only the select groups requiring authentication on each machine were allowed.

Website

Alma Linux 8.10, Gunicorn 23.0.0 + Python 3.8.17

The WWW server has been fully remodeled. The flask development server has been replaced with a production-level Gunicorn service, running in an isolated environment under a dedicated service worker. The website logic has been updated to sanitize input, create secure connections with WMS and DB systems, and enforce stricter security protocols. Code deployment and integrity checks are executed via a GitHub repository, connecting through a fine-grained access token. Notable backdoors that have been patched include a PAM authentication backdoor, bad sudoers rules, unnecessary SUID bits, and compromised listening services. Similar standard backdoors have been patched across all Linux machines.

Label Printer

Windows Server 2019 Standard Evaluation

A myriad of SMB-related vulnerabilities have been patched on the Label Printer, including path traversal and arbitrary code execution through the LabelWatcher system. The LabelWatcher was moved to the LocalService identity with granular access permissions. SMB access has been deeply restricted. Similar to AD, cumulative security updates have

been installed and Windows Defender has been updated. Malicious payloads, scheduled tasks, and running malware have been removed.

Warehouse Management System

Ubuntu 24.04.4 LTS, OpenJDK 21.0.10

Initially, WMS was running an insecure Java CRUD backend along with other listening services and an insecure shell. The backend application has been restricted to a service account and directory, with worker authorization for destructive endpoints. A custom logging service was also applied to better track usage of this backend. The inter-systems connections were also hardened, with the WWW and DB services having specific credentials to communicate with the WMS. Additionally, a socat backdoor and sid persistence script/service were removed, along with insecure mounts and password-resetting cron jobs.

Database

16.04.7 LTS + ESM, MySQL 14.14

The MySQL database itself has been updated with restrictive authorization permissions, permitting only warehouse workers to bind externally and allowing only updating of required tables in the correct tables. Backdoors were removed including world-writeable scheduled tasks, insecure group memberships, and a Name Service Switch backdoor, a persistence technique by the late IT admin John Leguizamo. Because this system runs a legacy OS (Ubuntu 16.04), Ubuntu Pro ESM was attached to ensure critical security patches continue to be applied.

Broad Hardening Techniques

In addition to specific mitigations, broad hardening techniques were applied to each system type. Linux machines were audited with Lynis, have deeper security logging reporting to Wazuh, and fail2ban for SSH brute-force mitigation. Firewall rules were set on each machine to further limit traffic. Flags were verified with the correct permissions in each respective area.

Incident Response

In the event of a detected or suspected compromise during the attack phase, our team will follow the following process:

Detection is primarily handled with Wazuh. Wazuh aggregates logs from all five machines using both syscheck and individualized configurations. A master dashboard displays all activity not generated by a service scanner in real time, as shown in excerpts below:

RDP

1–2 of 2 < 1 >

Time	agent.name	data.win.eventdata.targetUserName	data.win.eventdata.ipAddress	rule.description
Apr 22, 2026 @ 13:27:34.989	ad	oaoa	-	Non service account logged off.
Apr 22, 2026 @ 13:27:34.063	ad	oaoa	199.100.16.101	User: TEAM3\oaoa logged using Remote Desktop Connection (RDP) from ip:199.100.16.101.

1–2 of 2 < 1 >

WWW Web

1–7 of 7 < 1 >

Time	data.actor	data.http_method	data.http_path	data.endpoint	data.http_status	data.client_ip
Apr 22, 2026 @ 13:28:18.949	oaoa	GET	/order/getUserOrder	order.get_user_order	200	192.168.1.70
Apr 22, 2026 @ 13:28:16.956	oaoa	GET	/order	main.orders	200	192.168.1.70
Apr 22, 2026 @ 13:28:16.941	oaoa	POST	/auth/login	auth.login	302	192.168.1.70
Apr 22, 2026 @ 13:28:16.941	oaoa	GET	/	main.index	200	192.168.1.70
Apr 22, 2026 @ 13:28:14.940	anonymous	GET	/login	main.login	200	192.168.1.70
Apr 22, 2026 @ 13:28:12.939	anonymous	GET	/	main.index	200	192.168.1.70
Apr 22, 2026 @ 13:27:20.919	anonymous	GET	/	main.index	200	199.100.16.101

1–7 of 7 < 1 >

These systems allow us to manage critical alerts, such as SSH brute-forcing, as well as monitor possibly benign activity, such as website visits and successful logins.

Containment is performed at the firewall and service levels. If a service is determined to be compromised, its NAT mapping can be swiftly disabled, immediately cutting off external access while the internal service remains open for investigation and remediation. The WWW, WMS, SMB, and MySQL services each have individual configuration “kill-switches” that can temporarily remove either individual user’s access or specific features of each service while triage occurs.

Eradication and Recovery occur on a per-service basis, with WMS and WWW core services using a GitHub-integrated integrity check and rollback. For remote access, credential audits using security logs are executed, and all actions taken by users are also logged to remove and harden against any persistence mechanisms identified.

Lessons Learned are logged in a shared team document, with the detection method, attack vector, and remediations applied. These are used to both improve response in the future, as well as to inform our security reports throughout the day,